



Overview

0x2A

PENETRATION TEST REPORT *for* MEGAQUAGGA PUBLISHING



MQP

Version 1.0 (11/13/2025)

Prepared by **Jeremy Grantham**

Presented to **MEGAQUAGGA PUBLISHING**

DISCLAIMER: Simulated Lab Environment

EXECUTIVE SUMMARY

A structured penetration test was conducted against a simulated target web application in a controlled lab environment. Initial reconnaissance identified a lack of HTTPS configuration and a restrictive firewall, which was subsequently adjusted to allow testing. Comprehensive scanning tools were deployed, revealing several critical vulnerabilities, including outdated web server software and an out-of-date content management system with vulnerable plugins.

The identified vulnerabilities were successfully exploited to demonstrate potential unauthorized access to the system. This access was further escalated to simulate deep system compromise, highlighting the severity of the discovered weaknesses. The engagement was completed within the agreed scope, and all findings have been thoroughly documented. Detailed recommendations are provided to remediate these security vulnerabilities and enhance the overall security posture of the target system to prevent future breaches.



Scope

SCOPE

The scope of this assessment defines the boundaries and limitations of the penetration test to ensure clarity and compliance. This section outlines the specific target systems evaluated, their associated parameters, and the exclusions and restrictions applied during the engagement.

Primary objectives:

Assess whether the vulnerabilities identified in the previous vulnerability assessment can be exploited. Simulate real-world exploitation scenarios to determine the risk impact and potential consequences of those vulnerabilities.

Provide actionable recommendations to remediate these vulnerabilities.

Target system:

Target: Simulated web application lab environment

Assets Included: Public-facing web application and associated backend services within the approved lab scope.

Assets Excluded: Internal systems, unrelated subdomains, third-party services, denial-of-service testing, destructive testing, and excessive brute-force attempts.

Testing limitations:

The test will focus solely on exploitation of identified vulnerabilities, without:

Excessive brute-force attacks.

Denial-of-Service (DoS) or Distributed DoS (DDoS) testing, unless explicitly approved.

Data destruction or alteration

Methodology

METHODOLOGY

This section describes the systematic approach followed during the penetration testing process. Each step is critical to ensure thorough evaluation of the target systems while adhering to ethical and procedural standards. The methodology is divided into several phases:

Pre-Engagement and Planning:

The goal was to exploit target web application in a structured process that mimicked how an attacker might attack the system.

Information Gathering (Reconnaissance):

The assessment began with a review of the target web application, where initial reconnaissance identified that HTTPS was not enabled. Additional reconnaissance determined that ICMP traffic was being blocked by the pfSense firewall. Within the controlled lab environment, firewall rules were temporarily modified to permit ICMP traffic between the attacker system and the target web application to support reconnaissance activities. Connectivity was then verified, confirming that ICMP traffic was successfully allowed before continuing the assessment.

Scanning:

Metasploit was used to perform reconnaissance and service enumeration of the target web server. Scanning identified Apache 2.4.38 (Debian) running WordPress 5.3. Based on these findings, WPScan was used to enumerate installed WordPress components and assess their versions. The assessment identified multiple outdated plugins, including Social Warfare (v3.5.2), WP Advanced Search (v3.3.3), and WP File Upload (v4.12.2). These components were subsequently researched for known vulnerabilities to determine their potential security impact.

Exploitation:

Vulnerability validation identified the outdated Social Warfare WordPress plugin as the highest-risk component, confirming it was affected by CVE-2019-9978. After identifying the Cross-Site Scripting (XSS) vulnerability, a Python-based payload was developed to validate the finding. Successful validation confirmed the vulnerability, after which a controlled post-exploitation payload was used within the approved lab environment to assess potential impact and validate system access.

Post-Exploitation:

After initial access was validated in the controlled lab environment, limited post-exploitation analysis was performed to assess potential impact. Testing was stopped once sufficient evidence was collected to demonstrate risk while remaining within the approved scope of the engagement.

Reporting:

All findings, evidence, methodologies, and remediation recommendations were documented in this report. The documentation includes validated vulnerabilities, supporting evidence, risk assessments, and prioritized recommendations to improve the security posture of the assessed environment.



Findings

FINDINGS

This section presents the vulnerabilities identified during the penetration test, along with their potential impact and evidence collected. The findings are categorized by severity to assist in prioritizing remediation efforts.

CRITICAL VULNERABILITIES

This section describes critical vulnerabilities discovered during this assessment.

Vulnerability	Lack of encryption via HTTPS
CVE	Varied
Severity	High ▾
OWASP Top 10	A04 (Insecure Design) ▾
Risk	Common HTTP-Related Vulnerabilities Mixed Content Issues (HTTP/HTTPS) A frequent issue is the lack of proper HTTPS encryption (using HTTP instead of HTTPS), which leaves sensitive data unencrypted during transmission and can result in "Not Secure" warnings in browsers. Vulnerable HTTP Headers Plugins that manage HTTP headers can have vulnerabilities themselves, such as Server-Side Request Forgery (SSRF) or Cross-Site Request Forgery (CSRF), allowing attackers to gain unauthorized access or perform malicious actions. Unauthenticated Stored Cross-Site Scripting (XSS) via HTTP Headers Attackers can inject malicious scripts through spoofed HTTP header values (like the Referer header) which are then stored and executed when an administrator views the page. Host Header Redirection The insecure use of the Host header can allow an attacker to redirect users to malicious domains. Missing Security Headers The absence of recommended HTTP security headers (e.g., Content Security Policy, X-XSS-Protection) makes a site more vulnerable to attacks like XSS and clickjacking. Brute Force Attacks Attackers use automated tools to send numerous HTTP requests with different username and password combinations to the default login page (/wp-login.php).
Steps to exploit	1. Visited the web page during reconnaissance 2. Identified that the web application was not configured to use HTTPS.

Evidence	
----------	---

Vulnerability	Social-Warfare is using version 3.5.2 the latest version is 4.5.4
CVE	CVE-2019-9978.
Severity	Medium (CVSS SCORE: 6.1)
OWASP Top 10	A06 (Vulnerable and outdated components)
Risk	WordPress Social Warfare plugin versions prior to 3.5.3 suffer from a remote code execution vulnerability.
Steps to exploit	1. Performed reconnaissance and service enumeration. 2. Identified outdated WordPress core, themes, and plugins. 3. Researched known vulnerabilities affecting discovered components. 4. Validated exploitability of the outdated Social Warfare plugin in a controlled lab environment. 5. Confirmed limited low-privileged access. 6. Stopped testing after impact was demonstrated within the approved scope.
Evidence	i] It seems like you have not updated the database for some time. [?] Do you want to update now? [Y]es [N]o, default: [N]n [+] URL: [Exploit URL redacted] [+] Started: Mon Nov 10 15:43:29 2025 Interesting Finding(s): [+] Headers Interesting Entries: - Server: Apache/2.4.38 (Debian) - X-Powered-By: PHP/7.1.33 Found By: Headers (Passive Detection) Confidence: 100% [+] robots.txt found: [Exploit URL redacted] Interesting Entries: - /wp-admin/ - /wp-admin/admin-ajax.php Found By: Robots Txt (Aggressive Detection) Confidence: 100%

[+] XML-RPC seems to be enabled: [http://\[Exploit URL redacted\]/xmlrpc.php](http://[Exploit URL redacted]/xmlrpc.php)
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: [http://\[Exploit URL redacted\]/readme.html](http://[Exploit URL redacted]/readme.html)
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: [http://\[Exploit URL redacted\]/wp-cron.php](http://[Exploit URL redacted]/wp-cron.php)
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - <https://www.iplocation.net/defend-wordpress-from-ddos>
| - <https://github.com/wpscanteam/wpscan/issues/1299>

[+] WordPress version 5.3 identified (Insecure, released on 2019-11-12).
| Found By: Rss Generator (Passive Detection)
| - [http://\[Exploit URL redacted\]/feed/](http://[Exploit URL redacted]/feed/),
<generator><https://wordpress.org/?v=5.3></generator>
| - [http://\[Exploit URL redacted\]/comments/feed/](http://[Exploit URL redacted]/comments/feed/),
<generator><https://wordpress.org/?v=5.3></generator>

[+] WordPress theme in use: twentytwenty
| Location: [http://\[Exploit URL redacted\]/wp-content/themes/twentytwenty/](http://[Exploit URL redacted]/wp-content/themes/twentytwenty/)
| Last Updated: 2024-11-13T00:00:00.000Z
| Readme: [http://\[Exploit URL redacted\]/wp-content/themes/twentytwenty/readme.txt](http://[Exploit URL redacted]/wp-content/themes/twentytwenty/readme.txt)
| [!] The version is out of date, the latest version is 2.8
| Style URL: [http://\[Exploit URL redacted\]/wp-content/themes/twentytwenty/style.css?ver=1.0](http://[Exploit URL redacted]/wp-content/themes/twentytwenty/style.css?ver=1.0)
| Style Name: Twenty Twenty
| Style URI: <https://wordpress.org/themes/twentytwenty/>
| Description: Our default theme for 2020 is designed to take full advantage of the flexibility of the block editor...

| Author: the WordPress team
| Author URI: <https://wordpress.org/>
|
| Found By: Css Style In Homepage (Passive Detection)
| Confirmed By: Css Style In 404 Page (Passive Detection)
|
| Version: 1.0 (80% confidence)
| Found By: Style (Passive Detection)
| - [http://\[Exploit URL redacted\]/wp-content/themes/twentytwenty/style.css?ver=1.0](http://[Exploit URL redacted]/wp-content/themes/twentytwenty/style.css?ver=1.0), Match: 'Version: 1.0'

[+] Enumerating All Plugins (via Passive Methods)
[+] Checking Plugin Versions (via Passive and Aggressive Methods)

[i] Plugin(s) Identified:

[+] social-warfare
| Location: [http://\[Exploit URL redacted\]/wp-content/plugins/social-warfare/](http://[Exploit URL redacted]/wp-content/plugins/social-warfare/)
| Last Updated: 2024-09-17T20:18:00.000Z
| [!] The version is out of date, the latest version is 4.5.4
|
| Found By: Urls In Homepage (Passive Detection)
| Confirmed By:
| Urls In 404 Page (Passive Detection)
| Comment (Passive Detection)
|
| Version: 3.5.2 (100% confidence)
| Found By: Comment (Passive Detection)
| - [http://\[Exploit URL redacted\]/](http://[Exploit URL redacted]/), Match: 'Social Warfare v3.5.2'
| Confirmed By:
| Query Parameter (Passive Detection)
| - [http://\[Exploit URL redacted\]/wp-content/plugins/social-warfare/assets/css/style.min.css?ver=3.5.2](http://[Exploit URL redacted]/wp-content/plugins/social-warfare/assets/css/style.min.css?ver=3.5.2)
| - [http://\[Exploit URL redacted\]/wp-content/plugins/social-warfare/assets/js/script.min.js?ver=3.5.2](http://[Exploit URL redacted]/wp-content/plugins/social-warfare/assets/js/script.min.js?ver=3.5.2)
| Readme - Stable Tag (Aggressive Detection)
| - [http://\[Exploit URL redacted\]/wp-content/plugins/social-warfare/readme.txt](http://[Exploit URL redacted]/wp-content/plugins/social-warfare/readme.txt)
| Readme - ChangeLog Section (Aggressive Detection)
| - [http://\[Exploit URL redacted\]/wp-content/plugins/social-warfare/readme.txt](http://[Exploit URL redacted]/wp-content/plugins/social-warfare/readme.txt)

[+] wp-advanced-search
| Location: [http://\[Exploit URL redacted\]/wp-content/plugins/wp-advanced-search/](http://[Exploit URL redacted]/wp-content/plugins/wp-advanced-search/)
| Last Updated: 2024-11-05T18:15:00.000Z
| [!] The version is out of date, the latest version is 3.3.9.3
|
| Found By: Urls In Homepage (Passive Detection)
| Confirmed By: Urls In 404 Page (Passive Detection)

```
|
| Version: 3.3.3 (80% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
| - http://[Exploit URL redacted]/wp-content/plugins/wp-advanced-search/readme.txt

[+] wp-file-upload
| Location: http://[Exploit URL redacted]/wp-content/plugins/wp-file-upload/
| Last Updated: 2025-01-07T07:54:00.000Z
| [!] The version is out of date, the latest version is 4.25.1
|
| Found By: Urls In Homepage (Passive Detection)
| Confirmed By: Urls In 404 Page (Passive Detection)
|
| Version: 4.12.2 (50% confidence)
| Found By: Readme - ChangeLog Section (Aggressive Detection)
| - http://[Exploit URL redacted]/wp-content/plugins/wp-file-upload/readme.txt

[+] Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:02
<=====
===== > (137 / 137) 100.00% Time: 00:00:02

[i] No Config Backups Found.

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at
https://wpscan.com/register

[+] Finished: Mon Nov 10 15:43:38 2025
[+] Requests Done: 176
[+] Cached Requests: 7
[+] Data Sent: 60.532 KB
[+] Data Received: 549.099 KB
[+] Memory used: 276.379 MB
[+] Elapsed time: 00:00:08
```

EXPLOITATION AND POST-EXPLOITATION

The exploitation phase involved leveraging identified vulnerabilities to compromise the target systems, followed by post-exploitation activities to assess the potential impact. This section provides a detailed account of the actions taken.

EXPLOITATION PHASE

- Successfully exploited the vulnerable Social Warfare WordPress plugin (CVE-2019-9978) to validate unauthorized access within the approved lab environment.

POST-EXPLOITATION PHASE

- Following successful exploitation, a Meterpreter session was established within the approved lab environment to demonstrate post-exploitation capabilities and assess potential impact.

Recommendations

RECOMMENDATIONS

This section outlines the recommended actions to address the identified vulnerabilities and enhance the security posture of the target systems. Implementing these measures will help mitigate risks and prevent potential exploitation.

Recommendation #1: Configure website to use HTTPS

Implementing HTTPS involves three main steps to secure your website and optimize it for search engines:

Obtain and Install an SSL/TLS Certificate: Purchase a certificate from a trusted authority (or use a free one like Let's Encrypt). Generate a Certificate Signing Request (CSR) on your server and install the provided certificate files once validated. Many hosting providers offer simple installation processes.

Update Internal Links: Scan your website and replace all internal "http://" links (for images, scripts, and pages) with "https://" to avoid mixed content warnings and potential duplicate content issues.

Set Up 301 Redirects: Configure your server (via .htaccess for Apache, for example) to automatically and permanently redirect all old HTTP traffic to the new HTTPS version, ensuring a seamless and secure user experience.

Recommendation #2: Update Social-Warfare plugin

The highest-risk finding identified during this assessment was the outdated Social Warfare plugin. It should be updated immediately. Update the Social Warfare plugin as soon as possible, the standard procedure is to use the automatic update feature within the WordPress dashboard: first, back up your website to prevent data loss, then log in and navigate to the plugins section. Locate Social Warfare in the list and click the "Update now" link if an update notification is present. If you are using Social Warfare Pro, verify that your license key is active in the Registration tab to ensure access to automatic updates. If the standard method fails, a manual update is required. Again, perform a full site backup. Download the latest plugin .zip file from your account on the Warfare Plugins Downloads page. In your WordPress dashboard, go to Plugins > Installed Plugins, deactivate the plugin(s), and then delete the plugin files (your settings are preserved in the database). Next, go to Plugins > Add New, use the "Upload Plugin" button to install the newly downloaded .zip file, and finally, activate the plugin. After completing the process, remember to clear any caching plugins or CDN caches to ensure the new version of the plugin loads correctly.

Recommendation #3: Update all other plugins

Update all identified plugins to their latest supported versions after validating compatibility and performing a full backup.



Conclusion

CONCLUSION

A penetration test on [Exploit URL redacted] identified several security weaknesses, including outdated software, vulnerable plugins, and configuration issues, which allowed for successful unauthorized access. The findings highlight significant security weaknesses and include detailed recommendations for remediation to improve the system's overall security.